TP 2

Authentification sous Linux

1. Introduction

L'authentification joue un rôle important dans la vérification d'identité. Par exemple, lorsqu'une personne s'assoit devant un ordinateur, décroche un appareil mobile ou utilise un site Web, l'authentification permet de confirmer que la personne est bien celle qu'elle prétend être. L'authentification est une première étape importante avant de décider comment le système doit agir et ce qu'il faut autoriser.

2. Identité : utilisateurs et groupes

Les systèmes informatiques gèrent des comptes utilisateurs. Tandis que certains appareils, comme les téléphones, ont un seul compte, la plupart des ordinateurs en prennent en charge plusieurs. Chaque utilisateur dispose ainsi de son identité, de ses préférences et d'un accès personnalisé aux ressources.

Sur les systèmes Unix/Linux, chaque compte d'utilisateur est identifié par un numéro d'identification d'utilisateur (UID), il s'agit d'un identifiant numérique unique (un entier de 32 bits) attribué à chaque utilisateur d'un système. L'UID est utilisé pour distinguer les différents utilisateurs et constitue un élément fondamental du mécanisme d'authentification et d'autorisation des utilisateurs du système.

Application :

En supposant que vous êtes déjà connecté au système.

- *Comment vous vous êtes authentifié ?*

En ouvrant un terminal, utilisez les commandes ci-dessous pour connaître votre identité actuelle (ou l'identité du logiciel avec lequel vous interagissez) :

```
whoami
groups
id
```

- *Notez votre UID et votre nom d'utilisateur.*

Notez que votre compte est également membre d'un ou plusieurs groupes. Un groupe principal et une liste d'autres groupes.

N.B. Certains systèmes Linux créent un nouveau groupe principal pour chaque utilisateur, d'autres comme openSUSE ont un groupe partagé (dans ce cas nommé "utilisateurs") dont tous les utilisateurs normaux sont membres. Semblable à la relation entre les noms d'utilisateur et les UID, chaque groupe a un nom de groupe et un ID de groupe (GID).

Les informations sur les comptes d'utilisateurs sont stockées dans le fichier /etc/passwd, que tous les utilisateurs peuvent généralement lire.

- Affichez ce fichier : less /etc/passwd
  - *Identifiez la ligne qui correspond à votre compte d'utilisateur et décrivez ce qu'elle définît.*
  - *Est-ce que cela correspond aux informations que vous avez enregistrées précédemment ?*
  - *Trouvez également la ligne qui décrit le compte d'utilisateur root.*
  - *Où se trouve le répertoire personnel (home directory) de l'utilisateur root ?*
- Appuyez sur 'q' pour quitter less.
- Affichez également le fichier /etc/group : less /etc/group

Les groupes sont définis dans ce fichier, ainsi que les utilisateurs qui en sont membres.

- *Quels utilisateurs sont membres du groupe « video » ?*
- *A quels groupes êtes-vous membre ?*

Remarque :

- less /etc/passwd permet de consulter de façon sûre et interactive la liste des comptes utilisateurs du système Linux.
- less /etc/group permet de consulter les groupes du système et leurs membres, élément clé de la gestion des droits sous Linux.

- Exécutez la commande suivante : grep seed /etc/group
  - Quel est le rôle de cette commande ?

La commande "su" peut-être utilisée pour exécuter un programme (généralement un shell) en tant qu'un autre utilisateur, ce qui permet aux utilisateurs de passer d'un compte à l'autre dans l'invite de commande.

Maintenant, utilisez la commande useradd pour créer un nouvel utilisateur "student" par exemple.

Indication : Consultez la page de manuel de useradd, en exécutant "man useradd".

- Afin de créer un utilisateur avec un répertoire personnel par défaut, utilisez l'option suivante : useradd -m newuser
- Pour ajouter un mot de passe à l'utilisateur créé, utilisez la commande : passwd newuser

Changez l'identité en "student" : su - student

Exécutez : id

Comparez le résultat avec le précédent.

- Comment cela se compare-t-il à votre compte utilisateur normal ?

Exécutez la commande "id" en tant que root : sudo id

- Que remarquez-vous ?

3. Mots de passe, hash et sel

Essayez en premier lieu de répondre à ces deux questions :

- Quels sont les types de facteurs qui peuvent être utilisés pour vérifier l'identité d'un utilisateur ? Indice : par exemple, "quelque chose qu'il a".
- À quelle catégorie de facteurs d'authentification appartient un mot de passe ?

À l'origine, les mots de passe étaient stockés en clair. Pour plus de sécurité, on utilise une fonction de hachage à sens unique pour stocker uniquement le « hash » du mot de passe. Lors de la connexion, le mot de passe saisi est haché et comparé au hash enregistré.

Sous Linux, la commande « shasum » permet de générer un hash, utile notamment pour vérifier l'intégrité des fichiers:

shasum

Tapez "bonjour" sans les guillemets. Appuyez sur Ctrl-D (qui indique "EOF" ou fin de la saisie).

Répétez ce qui précède, avec le même mot de passe mais avec une légère différence ("bonjour.").

- *Les sorties sont-elles les mêmes ?*
- *Est-ce que ceci est utile? Pourquoi ?*

Pour l'authentification par mot de passe, le hachage doit encore être stocké. Sous Unix, les hachages de mots de passe étaient autrefois stockés dans le fichier /etc/passwd, lisible par tous. Aujourd'hui, ils sont généralement stockés dans /etc/shadow, auquel seul root (le super utilisateur) peut accéder.

Ouvrez un nouveau shell local (vous pouvez ouvrir un nouvel onglet en utilisant Ctrl-Shift-T).

Affichez le fichier shadow : sudo less /etc/shadow

- *Quel est le format général de ce fichier ? Explique chaque champ.*
- *Quel est le hash du mot de passe de votre compte utilisateur ?*
- *Notez le hash du mot de passe du nouveau compte utilisateur* "student"

Quittez less ("q").

Utilisez la commande passwd pour changer le mot de passe de "student"

Entrez un nouveau mot de passe de votre choix.

Visualisez le fichier shadow et confirmez que le mot de passe stocké a changé.

En vous référant au fichier shadow et à sa page de manuel ("man shadow"), répondez à ces questions :

- *Sous Linux, le mot de passe stocké dans /etc/shadow possède un préfixe qui spécifie la fonction de hachage utilisée. Quelle fonction de hachage est utilisée pour votre mot de passe ?*
- *Quand le mot de passe root a-t-il été modifié pour la dernière fois ?*
- *Même question pour votre compte utilisateur.*
- *Y-a-t-il un paramètre qui force le changement du mot de passe à une date précise ?*

Un sel (Salt) est une chaîne aléatoire, utilisée comme entrée supplémentaire dans une fonction de hachage à sens unique (concaténée au mot de passe). Le sel est généralement stocké avec le hachage. Par conséquent, le même mot de passe peut avoir différents hashs, tant que le sel est différent.

- *Est-ce une bonne chose ?*
- *Contre quel type d'attaque un sel se défend-il ?*

4. Utilisateurs et SSH

Connectez-vous à distance à un autre ordinateur en utilisant SSH, ou bien au système d'un camarade de classe ou, en dernier recours, à votre propre système.

Méthode 1 : **Tester SSH localement dans la VM (localhost)**

Exécutez les commandes suivantes pour vérifier et installer le serveur SSH dans la VM (Linux) :

```
sudo apt update
sudo apt install openssh-server
```

Ensuite, activer et démarrer le service :

```
sudo systemctl enable ssh
sudo systemctl start ssh
```

Exécutez la commande suivante pour vérifier : `systemctl status ssh`

Testez le service localement :

```
ssh username@localhost ou ssh localhost
```

Méthode 2 : **Tester SSH entre deux utilisateurs dans la même VM**

En supposant que vous avez créé un second utilisateur, testez la connexion entre eux.

Méthode 3 : **Tester SSH entre deux VM**

Dans ce cas, la VM1 est un serveur SSH et VM2 et client SSH.

Remarque :

Pour se connecter par ssh à un système distant, utilisez la commande :

```
ssh username@server_IP
```

Où username est le nom d'utilisateur sur le serveur.

Afficher les détails de tous les utilisateurs connectés au système : `who`

Lister tous les processus exécutés par tous les utilisateurs : `ps -eo user,comm`

Listez tous les processus s'exécutant en tant que root : `ps -o user,comm -u root`

Exécutez une commande pour lister tous les processus en cours d'exécution en tant qu'utilisateur normal.